



Storey — incident response runbook

What to do when something goes wrong with security or data

Last updated 2026-05-22

⚠️ This is an internal operations doc, not legal advice. When an incident happens, the most important thing is act quickly + document everything. If anything material happens, engage your lawyer in parallel with running this runbook.

Severity classification

Before you do anything, classify the incident. Different severities trigger different responses.

Level	Definition	Examples
S0 — Critical	Data exposed across tenants OR financial loss to customers OR auth compromised	RLS bug exposes one tenant's data to another · Service account credentials leaked · Mass account takeover
S1 — High	Service unavailable for >2 hours OR partial data exposure within a tenant	Supabase outage · One user's data visible to wrong user in same tenant · Payment integration broken
S2 — Medium	Bug affecting workflows but not data security · Service degraded but functional	Camera doesn't work · Photos not saving · Slow load times
S3 — Low	Cosmetic / UX issues	Layout broken on a phone model · Wrong icon · Translation error

S0 and S1 trigger this runbook. S2 and S3 go through the normal bug queue in [docs/TODO.md](#).

So (Critical) — full incident response

Phase 1 · Detect + Contain (*target: 30 minutes from awareness*)

- ☐ STOP — do not panic. Do not delete anything. Do not "fix" anything yet.
- ☐ Open a new private Google Doc: "Incident YYYY-MM-DD"
- ☐ Log timestamp of when you became aware
- ☐ Log how you became aware (customer email, log alert, your own notice)
- ☐ Take screenshots of any evidence — error messages, leaked data fragment, exposed UI
- ☐ Do NOT email customers yet
- ☐ Decide: is data still being exposed RIGHT NOW?

If yes — contain immediately:

- ☐ Log into Supabase Dashboard → Project Settings → Database
- ☐ Option A (most surgical): apply emergency RLS policy that locks the affected table:
`alter table <table_name> enable row level security;`
`create policy "emergency_lock" on <table_name> for all using (false);`
- ☐ Option B (heavy hammer): pause the project under Settings → General → Pause Project
This kills ALL access — use only if scope of exposure is unknown
- ☐ If auth is compromised, rotate the service-role key:
Supabase → Settings → API → Reset service role key
- ☐ Re-deploy edge functions that use the new key (npm run cap sync if affected)
- ☐ Push a frontend "service temporarily unavailable" banner if user-visible

Phase 2 · Assess scope (*target: within 2 hours*)

- ☐ Run queries to identify WHO was affected:
 - Which tenants? (tenant_id list)
 - Which users in those tenants? (auth.users + profiles)
 - What data was exposed? (specific tables / rows)
 - For how long? (timestamps of incident window)
- ☐ Save the query results in the incident doc
- ☐ Count affected users by tenant — needed for breach notification
- ☐ Engage your lawyer if affected_users > 0:
"Critical security incident. Need to know DPDP notification obligation in next 24h. Can we talk?"

Phase 3 · Notify affected users (*target: within 72 hours per DPDP*)

DPDP Section 8(6) requires breach notification "in such form and manner as may be prescribed." Real-world expectation: notify users within 72 hours of becoming aware.

- ☐ Draft a notification message using the template below
- ☐ Have your lawyer review the draft (one round, fast)
- ☐ Send via WhatsApp + email to every affected user
- ☐ Publish a public statement on storeyinfra.com (status page if you have one, otherwise a /security-notice page)
- ☐ Notify the Data Protection Board (DPDP Section 8(6)) — exact procedure pending Rules finalisation; check with lawyer
- ☐ Log every notification timestamp in the incident doc

Notification template — WhatsApp

Important security notice from Storey

[Day, date] we discovered a [brief description, e.g. "configuration issue that may have allowed limited data exposure"] in Storey.

What was exposed:

- [Specific fields – e.g. "worker names and contact phone numbers at NH-37 site"]
- [Approximate time window – e.g. "between [start] and [end]"]

What we did:

- [Specific containment action – e.g. "the issue was patched within 30 minutes of discovery"]
- [What's protected now – e.g. "the same issue cannot recur"]

What we recommend you do:

- [Specific advice – e.g. "no action needed; passwords were not affected"]
- [If applicable – e.g. "change any passwords that match those used elsewhere"]

What we will do:

- [Independent review – e.g. "engage an external security reviewer this week"]
- [Reporting – e.g. "file the required regulatory notification with the Data Protection Board"]
- [Ongoing communication – e.g. "share findings with you by [date]"]

We are deeply sorry this happened. If you have any questions, reply on WhatsApp directly. I am personally handling this.

– Karun
+91 98640 66898

Phase 4 • Root cause + remediation *(target: within 7 days)*

- ☐ Write a root-cause analysis in the incident doc:
 - What was the exact bug or vector?
 - Why didn't it get caught earlier?
 - What systemic fix prevents this class of issue?
- ☐ Implement the systemic fix as a migration or commit
- ☐ Add a regression test if possible (RLS audit query, schema check, etc.)
- ☐ Update CLAUDE.md or relevant docs with the learning
- ☐ Run the RLS audit query from docs/snippets/ on adjacent tables
- ☐ Brief affected users on the fix via follow-up WhatsApp

Phase 5 • Post-incident review *(target: within 14 days)*

- ☐ Schedule a 1-hour reflection – what surprised you, what worked, what didn't
- ☐ Update this runbook based on what you learned
- ☐ Document the incident in diary/YYYY-MM-DD.md as a "Wall" arc
- ☐ Decide: does this incident need follow-up customer communication? (e.g. compensation, refunds, contract amendments)
- ☐ Decide: does this incident need to be disclosed in future investor / acquisition due diligence? (Yes, almost always.)

S1 (High) — abbreviated response

For service outages or partial incidents that don't involve cross-tenant data exposure:

- ☐ Detect + contain (same as Phase 1 above, lighter)
- ☐ Status page / banner on storeyinfra.com if user-visible
- ☐ Affected-user WhatsApp message (don't wait for it to be perfect – speed > polish)
- ☐ Fix the immediate issue
- ☐ Brief root-cause analysis in the incident doc
- ☐ Post-fix communication to affected users

Skip Phase 3 (regulatory notification) unless DPDP scope applies.

Pre-incident readiness checklist

These should already be in place when an incident happens.

- ☐ Supabase Dashboard access – password in 1Password, recoverable
- ☐ Service role key – never in code, only in Supabase Edge env vars
- ☐ Lawyer's WhatsApp / phone – saved in your phone
- ☐ CA's WhatsApp / phone – saved in your phone
- ☐ One trusted family member knows where to find:
 - The lawyer's contact
 - The CA's contact
 - This document
- ☐ The list of all enrolled testers' Gmails (for breach notification)
- ☐ A pre-drafted "incident in progress" banner ready to push to storeyinfra.com

Sanity-test this runbook once a quarter — pretend an incident happened, walk through Phase 1 from awareness to first user notification. Find what's missing. Fix it.

What to NOT do during an incident

- **✗ Don't delete logs or evidence.** They may be your only defence.
 - **✗ Don't speculate publicly** before you understand the scope.
 - **✗ Don't blame the customer**, even if their misuse caused the exposure.
 - **✗ Don't promise specifics** you're not 100% sure of.
 - **✗ Don't try to "patch and pretend."** Disclosure is mandatory.
 - **✗ Don't communicate with users via personal email.** Use Storey-branded channels.
 - **✗ Don't tweet / WhatsApp Status updates** about it during the active incident.
 - **✗ Don't engage with PR firms or "reputation management"** during the crisis. Calm transparency > expensive spin.
-

The honest mindset

Most incidents at small scale are recoverable if handled openly and quickly. The thing that turns a small incident into an existential one is **silence and concealment**. Disclose early, disclose honestly, fix systemically, and your customers will mostly stay. Conceal, deflect, or delay — and you lose them all, plus regulatory action on top.

This runbook exists so that in the panic moment, you don't have to think — you just execute.